A DevOps Mario Developer Game Challenge with GRC

Multilevel Mario Engineer Challenge

BMK Lakshminarayanan

Value Stream Architect,
Bank of New Zealand

@LBMKRISHNA

ABOUT ME

BMK Lakshminarayanan

Value Stream Architect | DevOps Advocate

MISSION

Make your life better,

Make others life better,

Make the world better

Community

DEVOPS DAYS

CLOUD NATIVE SUMMIT

CLOUD NATIVE COMPUTING FOUNDATION AMBASSADOR

AMBASSADOR DevOps INSTITUTE Human of DevOps

CD.FOUNDATION

@LBMKRISHNA

Pictures Courtesy:
Internet
Super Mario Games (https://www.nintendo.com/)

A Developer on A Mission

Challenges to Unlock

Motivated Engineers keep going

@LBMKRISHNA

Wait you have “Security” – a new level to clear

What is this one?
Oh Governance!!!

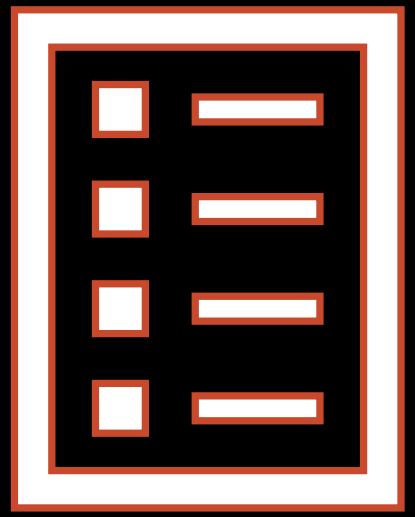
Most Enterprises/IT Organizations like Mario Game Challenge

Funding	Traditional– Initiative/Project Focused
Architecture / Design	Centralized & Committee Based
Governance	Overloaded Documentation, Processes
Risk & Audit	Paper/Document/Spread Sheet Based
Delivery Teams	Expectation to go faster

@LBMKRISHNA

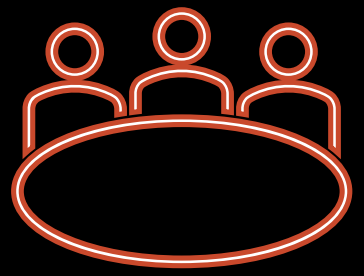
Fill – More Documents

Fill – More Templates



Tick – More Tick Boxes

Committee Approval



Monthly

Committee Approval

Quarterly

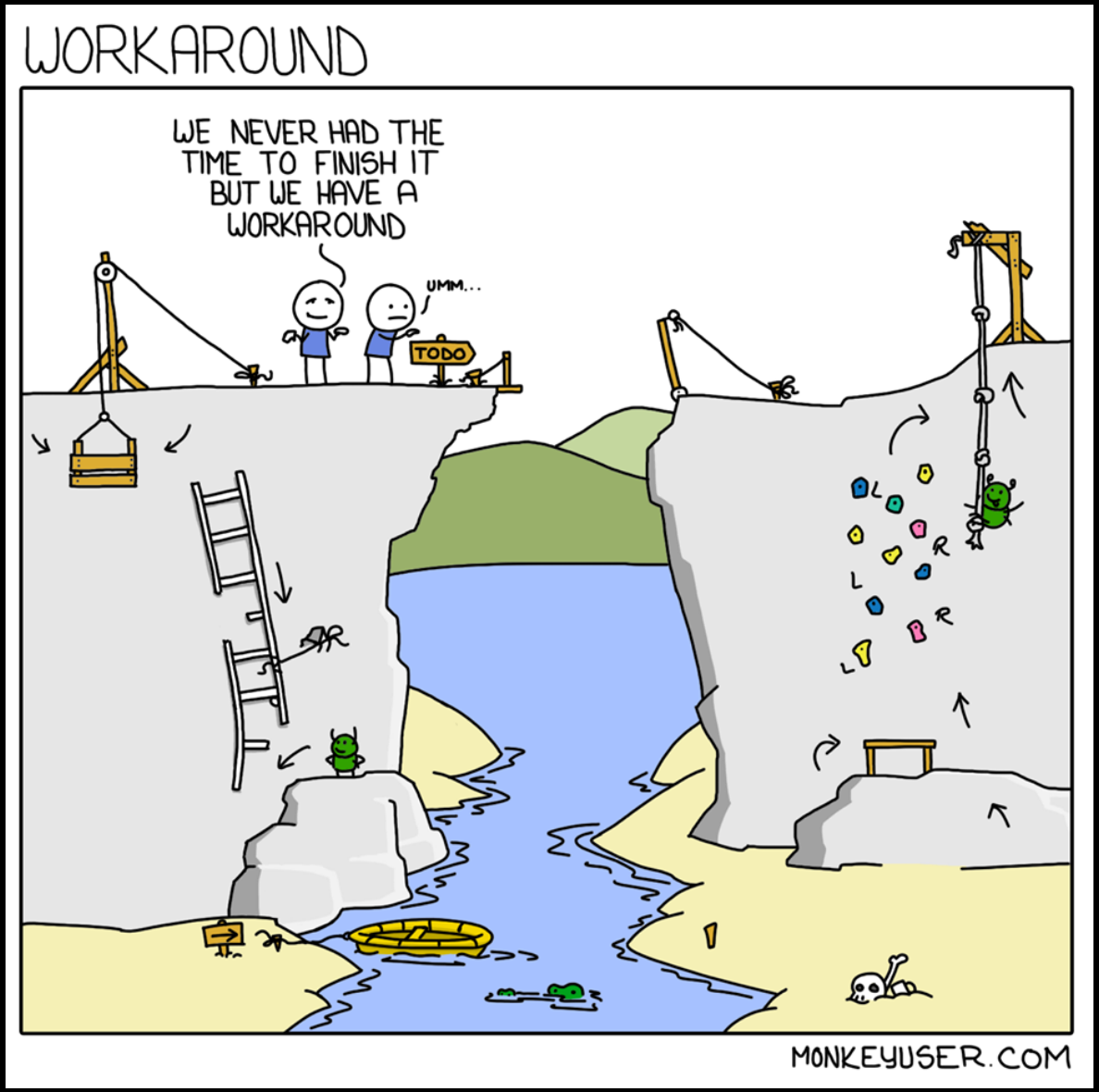
Committee Approval

Weekly

How fast could you deliver Customer Value?

Most Enterprises/IT Organizations like Mario Game Challenge

Mario (Dev, Testers, Ops) go thru these levels


WORKAROUND
WE NEVER HAD THE TIME TO FINISH IT BUT WE HAVE A WORKAROUND
UMM...
TODO
MONKEYUSER.COM

@LBMKRISHNA

Equifax: (At least) $575 Million

Home Depot: ~$200 million

Uber: $148 million

Yahoo: $85 million

Capital One: $80 million

Morgan Stanley: $60 million

British Airways: $26.2 million

Tesco Bank: $21 million

Target: $18.5 million

Anthem: $16 million

Ticketmaster: $10 million

Google: $7.5 million

Magecart Attack on Warner Music Group

Target Lost Data on 40 Million Cards

Adobe's Million Dollar Data Breach

Heartland Payment Systems Loses Processing Privileges

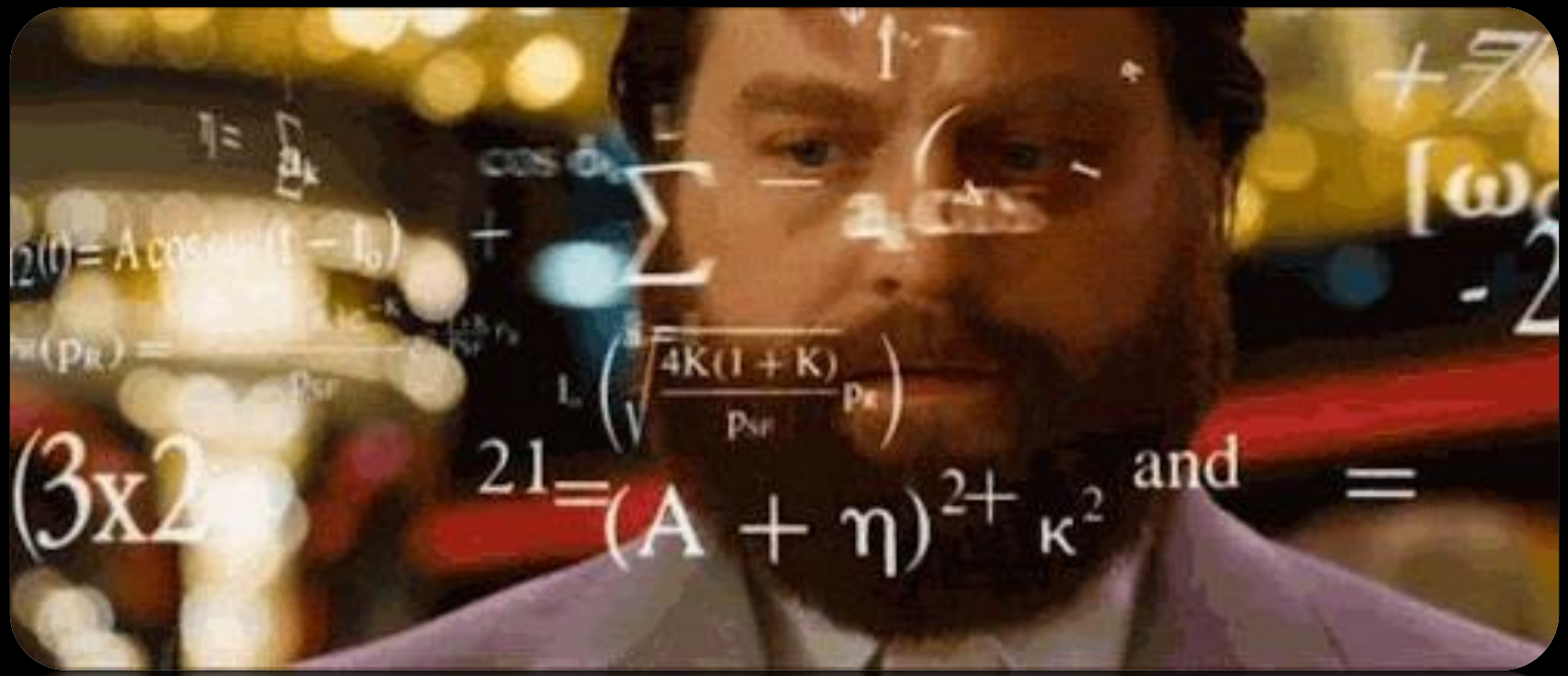
Equifax

https://www.informationisbeautiful.net/visualizations/worlds-biggest-data-breaches-hacks/

https://www.csoonline.com/article/2130877/the-biggest-data-breaches-of-the-21st-century.html

https://www.goanywhere.com/blog/the-5-biggest-pci-compliance-breaches

@LBMKRISHNA



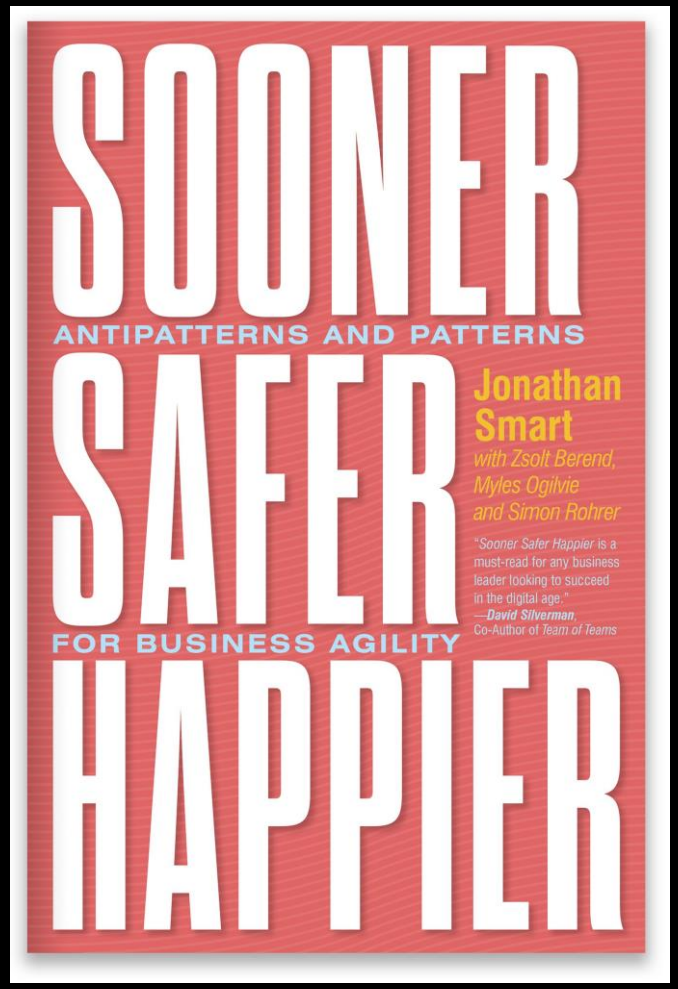
@LBMKRISHNA

From Here to Where?

The most critical metric is: how long it takes for an innovative idea to reach a customer

- Adrian Cockcroft, Vice President of Cloud

https://d1.awsstatic.com/executive-insights/en_US/ebook-cloud-for-ceos.pdf



Using Old Ways of Thinking to Apply new Ways of Working

- Jonathan Smart

https://itrevolution.com/sooner-safer-happier/

Centralized “Manual” Governance
“to”
Decentralized “Automated” Governance

Organizations today are subject to many regulations governing the protection of confidential information, financial accountability, data retention and disaster recovery, among others. They're also under pressure from shareholders, stakeholders and customers.

https://www.cio.com/article

“IT governance is the responsibility of executives and the board of directors, and consists of leadership, organizational structures, and processes that ensure that the enterprise’s IT sustains and extends the organization’s strategies and objectives.”

https://www.architectureandgovernance.com/

Compliance tick boxes
“to”
Compliance as Code

‘Compliance as Code’
is Organisational Capability

‘Compliance as Code’

Building compliance into development and operations, and wiring compliance policies and checks and auditing into Continuous Delivery so that regulatory compliance becomes an integral part of how DevOps teams work on a day-to-day basis

- Justin Arbuckle

Faking security controls
“to”
Baking them in delivery pipelines

No to tedious audits
“to”
Yes, to automated evidence

How fast could you deliver Customer Value?

Dear Auditor,

a love letter to auditors from devops,
where we promise to make life better

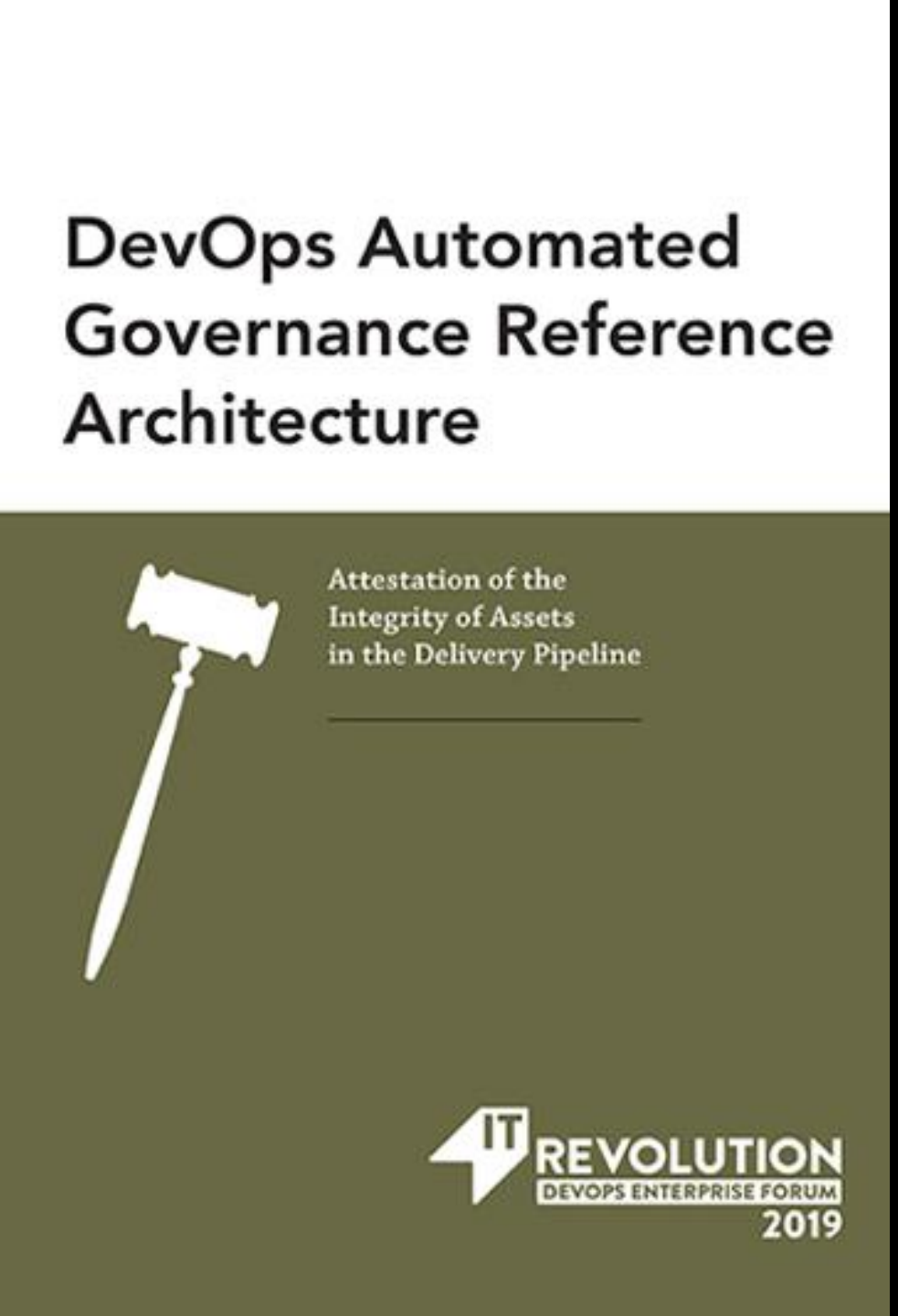
The team compiled a list of audit concerns and documented them in a DevOps Risk Control Matrix with lot of details around the controls, our practices and evidences that are collected to support the control.

http://dearauditor.org/

@LBMKRISHNA

The goal of the DevOps Audit Defence Toolkit is to educate IT management and practitioners on the audit process so they can demonstrate to auditors they understand the business risks and are properly mitigating those risks.

https://itrevolution.com/devops-audit-defense-toolkit/



As more and more DevOps practices are automated, it becomes harder to capture the data required to ensure all security and compliance concerns are met. ***Organizations need an automated way to track governance*** *throughout the entire software delivery process so they can attest to the integrity of all assets and to the security of all running applications.*

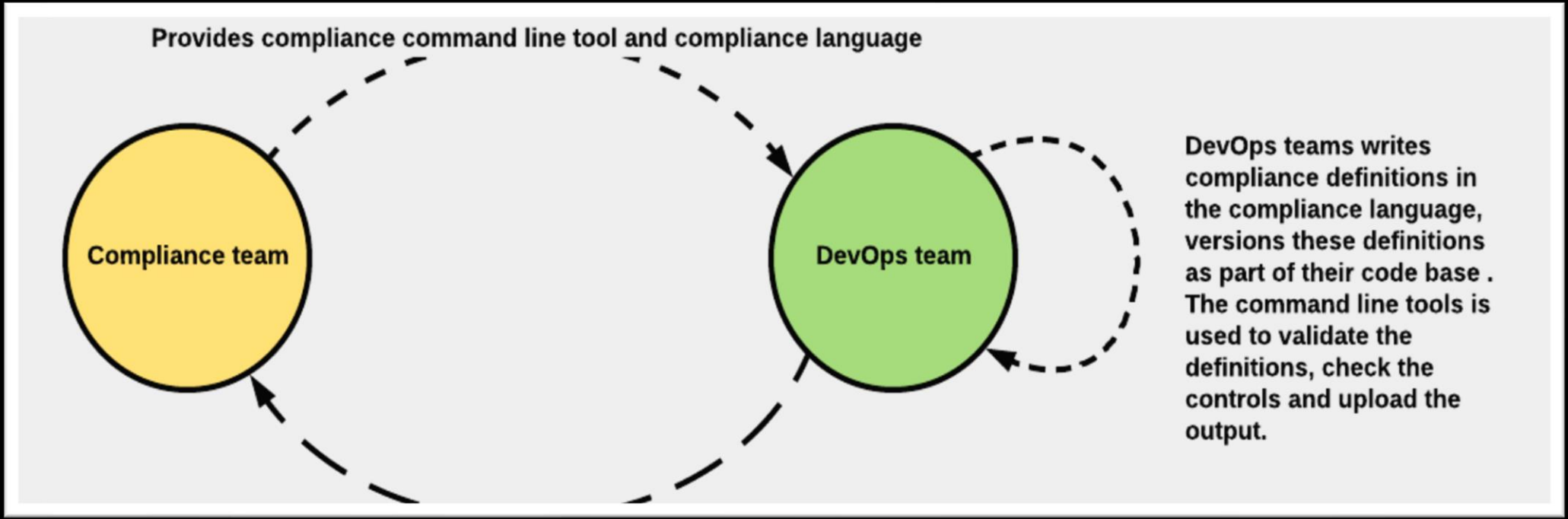
https://itrevolution.com/book/devops-automated-governance-reference-architecture/

The intent of this paper is to provide greater choice and options for corporations to consume cloud computing services by automating manual cloud governance processes. This paper seeks to accelerate compliance at the speed and scale of DevOps.

https://www.onug.net/app/uploads/2020/05/ONUG_WP_Automated-Cloud-Gov_Final.pdf

@LBMKRISHNA

Compliance as programming language



https://medium.com/faun/compliance-as-programming-language-da25f11be9d2

Policy-based control for cloud native environments

Flexible, fine-grained control for administrators across the stack

https://www.openpolicyagent.org/

DevOps Compliance and Controls Myths

1) **It is not possible to be agile and comply with general IT controls**

Investing in automation and 'controls by design' approaches make agile possible. By making these up front investments in culture and process, organizations find it easier to be agile and compliant. By contrast, organizations that rely heavily upon manual approaches or leave controls/compliance to the end struggle.

2) **DevOps means 'Developers manage production'**

This depends upon the needs of the organization. For example, a financial regulator may need to see segregation of duties evidence, which influences organizational design. Other organizations may not face these requirements. What's most important is that responses to operational issues are cross functional, leveraging the best of both development and operations.

3) **A compliant DevOps organization can only be achieved in the cloud**

While cloud technologies are an accelerator and enabler to a controlled/compliant organization, it's not the only way to achieve a controlled and compliant result. Organizations can adopt portions of the cloud to help with compliance, such as SaaS CI/CD tools and monitoring agents. Organizations can have their on-premises operations certified. Lastly, automation can be performed anywhere.

4) **Controls Slow down Continuous Integration/Continuous Deployment**

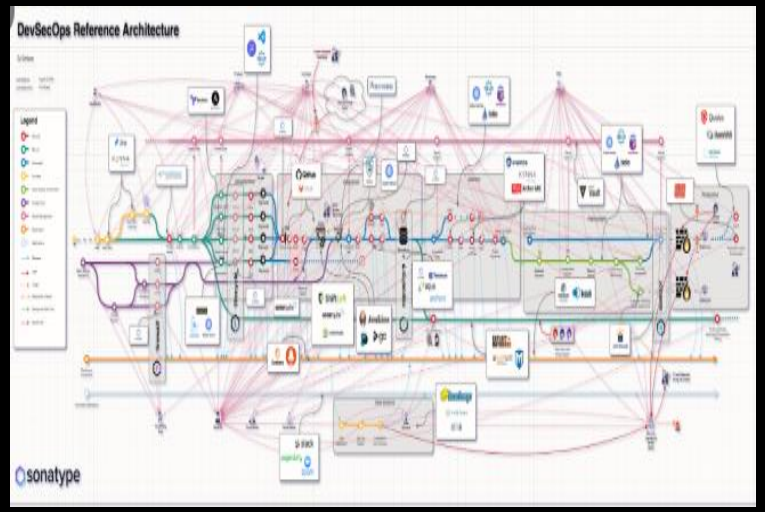
Through environment segregation and release pipeline approvers, DevOps teams can work together so that development integrates and deploys code to pre-production environments at their own pace. It is important that controls are gradually introduced or enhanced

5) **A DevOps Model introduces organizational risk**

The opposite is true. Repeatable, reusable processes are achieved by automation, replacing manual, error prone operations, reducing risk to organizations.

https://www.youtube.com/watch?v=7YiFiCGRQto

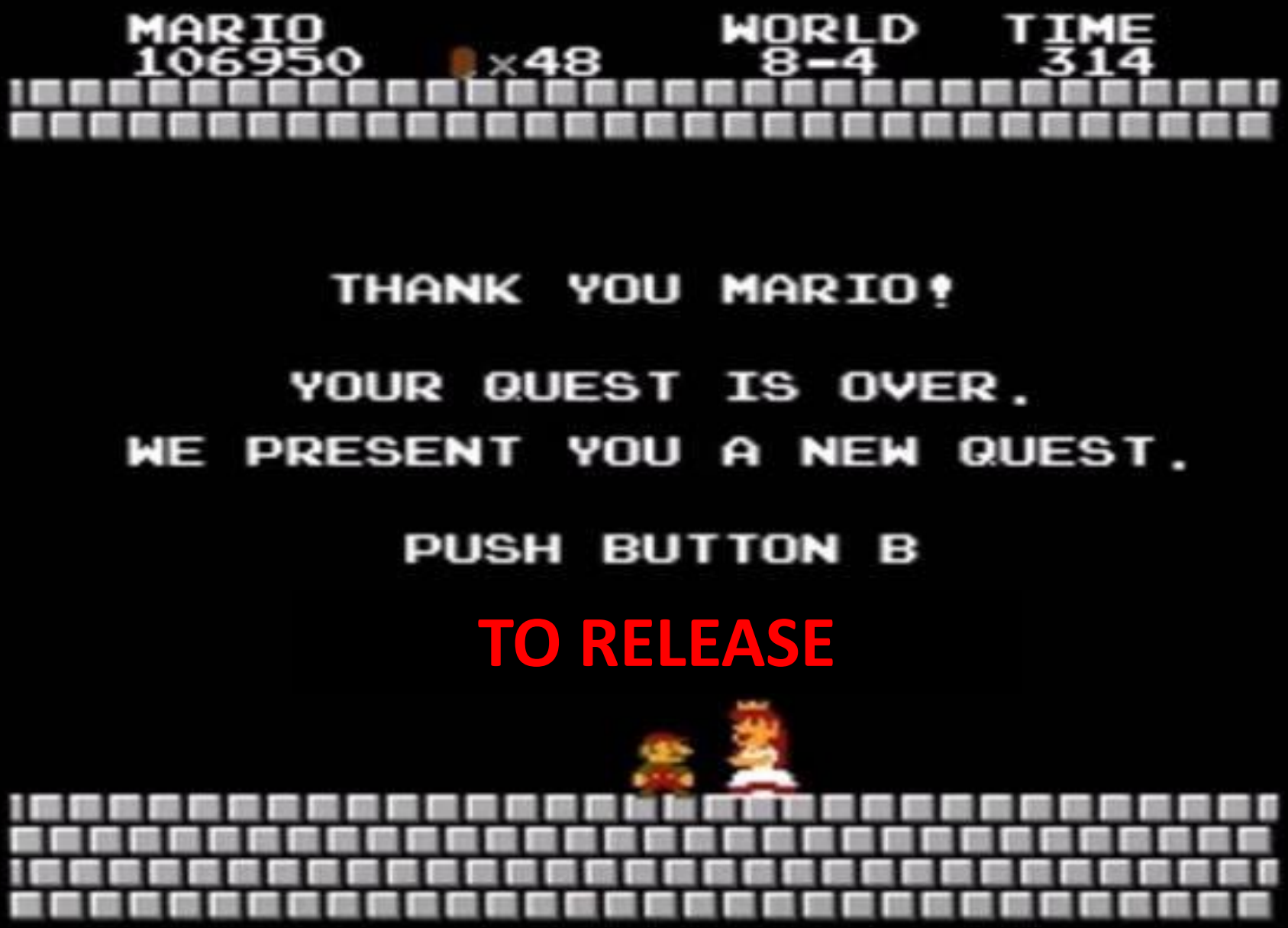
© 2019. For more information, contact Deloitte Touche Tohmatsu Limited.



Successful DevSecOps practices encompass people, processes, tools, and measurement. But where should you start, how can you validate your existing practices, or what are the possibilities? Then answer the following:

- *Where can we further automate manual, security, and business tasks?*
- *What DevSecOps tools and integrations are others deploying?*
- *What interactions do we need to be aware of or map out?*

https://www.sonatype.com/referencearchitecturetestdrive


MARIO
106950
×48
WORLD
8-4
TIME
314
THANK YOU MARIO!
YOUR QUEST IS OVER.
WE PRESENT YOU A NEW QUEST.
PUSH BUTTON B

TO RELEASE

A DevOps Mario Developer Game Challenge with GRC

Multilevel Mario Engineer Challenge

BMK Lakshminarayanan

Value Stream Architect,
Bank of New Zealand

@LBMKRISHNA